

ACTIVITY PACK

Activity 5 - Agent Governance and the Deployment Gate

Complete learner scenario, practice and security checklist

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Readme

Activity 5 - Agent Governance and the Deployment Gate

Course: AI Security for Autonomous AI Agents **Course Code:** TGS-2025060473 | **TSC:** ICT-INT-0052-1.1 **Block:** Day 2
- Autonomous Agent Security

At a glance

Duration	25 minutes
Format	Small groups of 3 - 4, plenary debrief
Type	Capstone synthetic simulation (SIM)
Learning Outcome	LO3
K/A statements assessed	A1, A2

Purpose

Capstone. Learners act as an AI governance board deciding go/no-go on an autonomous banking agent, reading evaluation data for bias and hallucination, applying PDPA/PDPC and the IMDA agentic framework, and setting autonomy limits and accountability.

Files in this folder

File	Audience	Use
SCENARIO.md	Learner	The case study narrative, artefacts and data
DISCUSSION-QUESTIONS.md	Learner	The five questions to work through in groups
SECURITY-CHECKLIST.md	Learner	Organisational, autonomy, Responsible AI, PDPA and operations deployment gate
Activity-5-*.pdf	Learner	Printable full learner pack including the deployment checklist

How to run it

1. **Set up (5 min).** Form groups of 3 - 4. Issue SCENARIO.md and DISCUSSION-QUESTIONS.md. Trainer debrief notes are supplied separately and are not stored in the learner-facing Activities folder.
2. **Group work (10 minutes).** Groups work the five questions in order. Circulate; the questions are designed to be argued, not looked up.
3. **Presentation (5 minutes).** Each group presents its answer to one nominated question.
4. **Debrief (5 minutes).** Use the separate trainer notes to draw out the teaching points and correct recurring misconceptions.

Learner workflow

1. Reproduce the aggregate and segment calculations from the SIM data and state what the aggregate hides.
2. Map the purpose, notification, protection, retention, transfer and breach-response obligations for each personal-data surface.
3. Classify all ten capabilities as agent alone, human approval required or prohibited, based on impact and reversibility.
4. For each approval, specify the exact action, target, data, destination, evidence and rollback shown to the reviewer.
5. Verify the guardrails, identity scopes, sandbox, egress, memory provenance, logging, monitoring, kill switch and recovery evidence.
6. Decide go, conditional go or no-go, naming the accountable owner, unmet conditions, review date and release evidence.

7. Define the notice, challenge route, human escalation and remedy available to an affected person.

Required evidence

- Reproducible aggregate and segment-risk calculations using only the supplied SIM data.
- A data inventory and autonomy classification for all ten capabilities.
- An approval matrix covering every irreversible or high-impact action.
- A deployment decision whose conditions each have an owner, test, expiry or review date and re-test trigger.
- A human challenge, review and remedy route.

Acceptance criteria

The submission passes when all ten capabilities are classified; every high-impact or irreversible action is prohibited or behind deterministic approval; every release condition can objectively pass or fail; and an affected person can reach a human reviewer and obtain a remedy.

The slide deck remains concept-led. These learner procedures are also reproduced in the Learner Guide.

Alignment

Every question in DISCUSSION-QUESTIONS.md is tagged with the K or A statement it evidences. This activity contributes to **LO3** and is assessed through the Case Study.

This material belongs to Tertiary Infotech Pte Ltd (UEN: 20120096W). All Rights Reserved.

Scenario

Activity 5 - Scenario

Agent Governance and the Deployment Gate

Course: AI Security for Autonomous AI Agents (TGS-2025060473) **Duration:** 25 minutes | **Format:** Small groups of 3 - 4 acting as one governance board | **Type:** Capstone synthetic simulation

Evidence status: SIM. The organisation, people, customer counts, financial values, evaluation results, targets, segment labels, and projected benefits are synthetic classroom data. They are not market evidence or a claim about any real bank or population.

The simulated organisation

Meridian Bank Singapore is a mid-tier retail and SME bank with 1.4 million customers, 26 branches, and a digital-first strategy under pressure from three larger incumbents and two digital banks. It is a Singapore-incorporated entity, regulated by MAS, and is an **organisation** under the PDPA for personal data it collects, uses or discloses. A vendor may separately act as a data intermediary when it processes personal data on the bank's behalf.

Its Collections and Customer Assistance division handles customers who fall behind on unsecured credit - personal loans, credit cards, SME working-capital facilities. The division employs 118 officers and handles roughly **31,000 delinquency cases per year**. Median time from first missed payment to first meaningful customer contact is **nine days**. For this synthetic business case, the bank's commissioned internal analysis assumes that intervention within 72 hours materially improves outcomes for the customer, not only for the bank; it is not presented as external industry evidence.

The proposal

The Chief Digital Officer, **Rachel Tay**, is asking the AI Governance Board to approve production deployment of **"ARIA"** - Assisted Recovery and Intervention Agent.

ARIA is not a chatbot. It is an **autonomous agent**: a planning loop over a commercial frontier model, with tool access and persistent per-customer memory. Its mandate is to detect early delinquency, contact the customer, understand the situation, and **agree and enact a restructuring** without an officer in the loop for standard cases.

What ARIA is permitted to do in the proposed design

#	Tool / action	Reversible?	Visible to customer?
1	Read full customer profile: account history, transactions, employment field, CPF contribution flag, demographic data	n/a	No
2	Read the bank's collections policy and hardship guidelines (RAG over an internal document store)	n/a	No
3	Initiate outbound contact by SMS, email and in-app message	No	Yes
4	Conduct a multi-turn conversation about the customer's financial circumstances	n/a	Yes
5	Offer and execute a payment-plan restructuring up to S\$8,000 exposure	Partially	Yes
6	Apply a hardship flag to the account	Yes, but recorded	Not directly
7	Waive late fees up to S\$300 per case	Yes	Yes
8	Escalate the account to the external debt recovery agency	No	Yes, severely
9	Write a case summary into the CRM, used by human officers and by future ARIA sessions	Persistent	No
10	Submit a data point to the credit bureau reflecting restructuring status	No	Consequential

Actions 1 - 9 are proposed as **fully autonomous**. Action 10 is proposed as autonomous "because it is a factual reporting obligation, not a decision."

The business case

Metric	Today	Projected with ARIA	Basis
Median days to first contact	9.0	0.4	Agent runs continuously
Cases handled per year	31,000	31,000	Same volume
Officer FTE required	118	34	Vendor estimate
Annual operating saving	-	S\$6.1m	Finance projection
Cure rate (customer returns to good standing)	41%	55% (projected)	Vendor pilot data, different market

Rachel Tay's paper to the board states: *"Every week we delay costs us S\$117,000 and leaves customers in distress nine days longer than necessary. The ethical case for ARIA is as strong as the commercial one."*

She is not wrong about the harm of the status quo. That is what makes this decision difficult.

The evaluation results

The bank's model risk team ran a 6,000-case retrospective evaluation, replaying real historical cases through ARIA and comparing its proposed action against the outcome a senior officer panel judged correct. Results were tabled 48 hours before the board meeting.

Overall performance

Metric	Result	Internal target
Recommended-action accuracy (all segments)	91.2%	≥ 90%
Hallucination rate - ARIA asserted a policy provision, fee, or account fact that does not exist	4.7%	Not specified
Of those hallucinations, proportion that resulted in a wrong tool call being executed	38%	Not specified
Policy-adherence violations (offer outside mandated bands)	2.1%	≤ 1%
Median conversation turns to resolution	6	-
Cost per case	S\$0.42	-

Accuracy by customer segment

Customer segment	Cases in eval	Accuracy	False "escalate to recovery agency" rate	Median offer generosity index
Singapore citizen, salaried, English primary	2,410	94.6%	1.2%	1.00 (baseline)
Singapore citizen, salaried, non-English primary	890	89.1%	3.4%	0.91
Singapore PR, salaried	640	90.8%	2.1%	0.96
Work Permit / S Pass holder	510	82.3%	7.8%	0.74
Self-employed / gig economy income	780	84.9%	6.1%	0.79
SME sole proprietor	470	88.4%	4.0%	0.88
Age 60+	300	86.7%	5.2%	0.93

The model risk lead's note reads, in full:

"Aggregate accuracy of 91.2% clears our threshold. Segment variance is expected given training data distribution and case-mix differences. Recommend proceed with monitoring."

One further finding, filed as low severity

During the evaluation ARIA generated internal automation scripts to reconcile payment plans. In 11 instances it imported Python packages that **do not exist** - plausible-sounding names assembled from its training distribution. A developer had pip-installed two of them before noticing. Neither resolved. The finding was logged as *"minor code quality issue"*.

What the board already knows

- ARIA's supplier is a well-regarded international vendor. Meridian operates the deployment and,

using the PDPC's 2 June 2026 proposed consultation vocabulary, is the **system deployer**.

- The customer notification currently drafted for the terms and conditions reads:

"We may use automated systems and new technologies to improve our products and services."

- No customer-facing disclosure currently states that the counterparty in a collections conversation is an AI agent.

- ARIA's per-customer memory is retained indefinitely, "for continuity of service."

- Conversation transcripts, model prompts and tool-call logs are stored in the vendor's regional cloud tenancy. Nobody has asked which region.

- The bank's audit trail cannot presently distinguish an action taken by ARIA from one taken by a human officer. Both appear in the CRM as "Collections - system."

- A director has asked whether ARIA can be extended next year to **SME credit decisioning**.

Your role

You are the **AI Governance Board of Meridian Bank Singapore**. Your members are the Chief Risk Officer (chair), the Data Protection Officer, the Head of Collections, an independent non-executive director, and the Head of Model Risk. Rachel Tay is presenting; she is not a member and does not vote.

You must return a **written decision** to the Board of Directors. It must contain:

1. **Go / no-go / go-with-conditions** - with the conditions specified precisely enough to be tested.
2. **An autonomy matrix** - for each of ARIA's ten capabilities: *alone*, *with human approval*, or

never.

3. **A human accountability model** - who is answerable for an ARIA decision, at what checkpoints, and what the override and appeal path is for a customer.

4. **Monitoring and audit requirements** - what is logged, what is measured, what triggers suspension.

You have 25 minutes. Your decision will be read by people who will lose S\$117,000 a week if you are too cautious, and who will front a MAS and PDPC enquiry if you are not cautious enough.

Discussion Questions

Activity 5 - Discussion Questions

Agent Governance and the Deployment Gate

You are the AI Governance Board. Work through all five questions and produce the four deliverables named in the scenario. Nominate one person to deliver the board's decision - three minutes, no slides, as you would to a Board of Directors. You have 25 minutes.

This is the capstone. Everything from the previous four activities is in scope: trust boundaries, prompt injection, poisoning, framework selection, agent architecture and excessive agency.

Q1 - Read the evaluation results as a governance board, not as a data scientist (A1)

The model risk lead recommends proceeding on the strength of 91.2% aggregate accuracy.

- Explain what the **segment table** shows that the aggregate figure conceals, and quantify the gap between the best-served and worst-served segments on **both** accuracy and false escalation rate.

- The false "escalate to recovery agency" rate is **7.8% for Work Permit / S Pass holders** against

1.2% for the baseline segment. Translate that into **people per year** at the bank's volume, and describe what actually happens to one of those people.

- The lead attributes the variance to "training data distribution and case-mix differences." Assess that explanation. Does identifying a cause discharge the bank's responsibility for the effect?

- State whether an aggregate accuracy threshold is a **fit-for-purpose governance control** for a system that acts on individuals, and say what you would replace or supplement it with.

Q2 - Hallucination as a security control failure, not a quality issue (A1)

ARIA hallucinates on **4.7%** of cases, and **38%** of those hallucinations result in a **wrong tool call being executed**.

- Compute the effective rate of wrong executed actions per 1,000 cases, and per year at 31,000 cases.

State what that number means when the tool in question is *escalate to the debt recovery agency* or *submit a credit bureau data point*.

- OWASP treats **misinformation** as an application-security risk rather than only a quality issue.

Justify that treatment using ARIA specifically. Why is a hallucination that drives a tool call categorically different from one that produces a wrong sentence?

- The evaluation logged 11 instances of ARIA importing **non-existent Python packages**, two of which

a developer attempted to install. Name this failure mode using its OWASP 2026 identifier and title, explain the attack it invites, and say why "minor code quality issue" is the wrong severity.

- Identify **three limitations** of ARIA that are not solved solely by adding more training data, and

explain what each one implies for the autonomy you are willing to grant.

Q3 - Discharge the PDPA and PDPC obligations (A2)

Meridian Bank operates the deployment and, using the PDPC's 2 June 2026 proposed consultation vocabulary, is the **system deployer**.

- Under the current PDPA obligations, explain what it means for the deploying organisation to retain

its own statutory duties in practice, and why a vendor's reputation or contractual assurances do not transfer those duties. You may use the PDPC's 2 June 2026 proposed GenAI consultation text as a labelled proposal, not as final law or final guidance.

- Assess the drafted notice - **"We may use automated systems and new technologies to improve our products and services"** - against the guidelines' consent and notification requirements. Rewrite it so it would survive scrutiny, and state what it must disclose that the current wording omits.

- The proposed consultation text highlights **new data surfaces**: end-user prompts, generated outputs, **agent** and tool

activity data**, and internal enterprise data. Identify every such surface ARIA creates, say who holds it and where, and flag the ones the bank has not inventoried.

- ARIA's per-customer memory is retained indefinitely. Address this against **retention limitation**

and the access-and-correction obligations. What does a customer's correction request even mean once a wrong belief is embedded in agent memory and has already influenced three conversations?

Q4 - Apply the IMDA agentic governance framework (A2)

IMDA's Model AI Governance Framework for Agentic AI (January 2026, updated June 2026) sets out four dimensions: **risk assessment, human accountability, technical controls, and end-user responsibility**.

- Work ARIA through IMDA's autonomy calibration: **impact** (domain sensitivity, data access, action

scope) x **likelihood** (autonomy level, task complexity, third-party dependencies). Show your reasoning, and place ARIA on the resulting scale.

- Define the **human approval checkpoints** IMDA requires for "higher-risk or irreversible actions."

Go through ARIA's ten capabilities and defend where you place each. Say explicitly which capabilities you judge **unsuitable for an agent entirely** - IMDA states plainly that some use cases are.

- IMDA prefers **structural, system-level technical controls over prompt-based ones**. Give two

controls the board should require for ARIA that satisfy this preference, and contrast each with the prompt-based version a project team would propose instead.

- IMDA requires auditing **override rates and response times**. The bank's audit trail cannot

currently distinguish ARIA's actions from an officer's. Explain why that single gap undermines the entire accountability dimension, and specify what must change.

Q5 - Decide, and own the societal consequence (A2, A1)

Deliver your board decision.

- State **go / no-go / go-with-conditions**, and make every condition **testable** - a condition that

cannot be failed is not a condition.

- Set out your **human accountability model**: the named accountable role, the approval checkpoints,

the override path, and the customer's route to challenge an ARIA decision and reach a human. Say how the bank satisfies IMDA's **end-user responsibility** dimension - what customers and officers are told about ARIA's capabilities, data access and escalation route.

- Confront the ethical and societal argument on both sides. Rachel Tay is right that the status quo

leaves distressed customers waiting nine days, and that S\$117,000 a week is a stated synthetic business-case cost.

Your controls will slow ARIA down. Justify your position **in terms of who bears the cost of each choice** - and note which groups bear the cost of a false escalation and which bear the cost of a delayed deployment. They are not the same people.

- A director wants ARIA extended to **SME credit decisioning** next year. Give the board your position

now, with reasons, before the momentum makes it undiscussable.

Security Checklist

Activity 5 - Agent Deployment Gate Checklist

Organisational accountability

- ☐ Business, technical, security, privacy, model-risk and operational owners are named.
- ☐ Leadership has approved the use case, risk tolerance and non-agent alternative.
- ☐ Users are told when an agent acts, what it can access and how to challenge outcomes.

Bound autonomy

- ☐ Each capability is classified by impact, reversibility, data sensitivity and likelihood.
- ☐ Read, recommend, prepare and execute permissions are separated.
- ☐ Irreversible, legal, financial, privacy and safety actions have deterministic approval or are prohibited.
- ☐ Approval shows exact fields, recipient, amount, target and reason and expires after one action.
- ☐ Agent identity, credentials, tools, skills/plugins, recipients, cost, retries and duration are bounded.

Fairness, reliability and privacy

- ☐ Accuracy, false escalation and outcomes meet per-segment floors and disparity limits.
- ☐ Hallucination and unsafe-action rates are converted into expected annual affected cases.
- ☐ Prompt, output, memory, tool and log personal-data surfaces are inventoried and minimised.
- ☐ PDPA purpose, notice/consent where applicable, protection, transfer, retention and rights are evidenced.

Responsible AI assurance

- ☐ The board has tested both attacker-driven misuse and foreseeable harmful use without an attacker.
- ☐ Outcome, denial, escalation and false-positive results are segmented by affected group.
- ☐ Users receive clear notice of agent use, material limitations, data/tool reach and the human escalation route.
- ☐ Affected people can obtain human review, correction and remedy for consequential outcomes.
- ☐ Provider, builder, deployer, operator, approver and end-user responsibilities are documented without gaps.
- ☐ Independent or second-line review is required where impact exceeds the organisation's defined threshold.

Operations

- ☐ Monitoring covers identity, tool sequences, approvals, overrides, egress, cost and policy denials.
- ☐ Kill switch, rollback, credential revocation and manual fallback are tested.
- ☐ Incident response includes the DPO, evidence preservation and breach-notification assessment.
- ☐ Model, corpus, tool, skill/plugin or policy changes automatically trigger re-testing.
- ☐ Residual risks have owners, mitigations and expiry dates.

Board decision

- ☐ Go.
- ☐ Go with explicit conditions and expiry.
- ☐ No-go; the use case cannot be bounded within risk tolerance.